

Kibernetinio Saugumo Pilnas Inžinerinis Žinynas

Kibernetinio Saugumo Incidentų Reagavimo Atmintinė (Playbook) > **Kritinė taisyklė

#1 (Pirmosios 15 min):** NIEKADA iš karto neperkraukite serverio (`reboot`) ir neišjunkite maitinimo. Perkrovus sistemą, negrįžtamai prarandama operatyviojoje atmintyje (RAM) esanti informacija, atidaryti tinklo lizdai ir paslėpti procesai.

1. Incidento reagavimo fazės (NIST SP 800-61 / SANS)

1. **Identifikavimas:** Jvykio patvirtinimas, anomalijų fiksavimas.

2. **Izoliavimas (Containment):** Tinklo atskyrimas, kad kenkėjas neplistų į kitus serverius.

3. **Šalinimas (Eradication):** Kenkėjo pašalinimas, pažeidžiamumų užtaisymas.

4. **Atkūrimas (Recovery):** Sistemos atstatymas iš patvirtintos švarios kopijos.

5. **Pamokos (Lessons Learned):** Incidento ataskaita ir prevencijos tobulinimas.

2. Skubios komandos tiesioginei analizei (Live Forensics)

A. Vartotojai ir aktyvios sesijos: `` ` bash w who -u last -n 25 lastb -n 25 || sudo lastb -n 25 awk -F: '(\$3 == 0) {print \$1}' /etc/passwd `` `

B. Tinklo jungtys ir atviri prievadai: `` ` bash ss -tulpn lsof -i -P -n netstat -antp | grep ESTABLISHED `` `

```
### C. Įtartini procesai: ```bash ps aux --sort=-%cpu |
head -n 15 ls -la /proc/*/exe 2>/dev/null | grep -E
"/tmp|/dev/shm|/var/tmp)" # Konkretaus PID analizė: lsof
-p <PID> ls -la /proc/<PID>/cwd ```
```

```
### D. Įsitvirtinimo mechanizmų (Persistence) patikra:
```bash crontab -l ls -la /etc/cron*
/var/spool/cron/crontabs/ find /etc/systemd/system/ -
type f -mtime -2 -ls cat /root/.ssh/authorized_keys
2>/dev/null ``` ---
```

```
3. Skubus izoliavimas (Containment) ```bash
Izoliuoti tinklo interfeisą: sudo ip link set eth0 down #
Arba sustabdyti procesą jo nenužudant: kill -STOP <PID>
```
```

SSH ir Serverių Grūdinimo Vadovas:

```
## 1. Perėjimas prie Ed25519 raktų ```bash ssh-keygen -
t ed25519 -a 100 -C "admin@company.com" ssh-copy-id
-i ~/.ssh/id_ed25519.pub user@server_ip chmod 700
~/.ssh chmod 600 ~/.ssh/id_ed25519 chmod 644
~/.ssh/id_ed25519.pub ``` ---
```

```
## 2. Griežta /etc/ssh/sshd_config konfigūracija ```ini
Port 2222 PermitRootLogin no PasswordAuthentication
no ChallengeResponseAuthentication no
PubkeyAuthentication yes MaxAuthTries 3 AllowUsers
administratorius deploy ClientAliveInterval 300
ClientAliveCountMax 2 X11Forwarding no ``` >
**Svarbu:** Prieš perkraudami SSH servisą, BŪTINAI
patikrinkite konfigūraciją: ```bash sudo sshd -t && sudo
systemctl restart ssh ```
```

```
## 3. Fail2ban apsauga nuo brute-force Konfigūracija faile  
`/etc/fail2ban/jail.local`: `` `ini [sshd] enabled = true  
port = 2222 mode = aggressive bantime = 24h findtime =  
10m maxretry = 3 `` ` bash sudo systemctl restart  
fail2ban sudo fail2ban-client status sshd `` `
```

API Saugumo Standartai ir OWASP API Top 10

1. OWASP API Top 10 Pažeidžiamumai

1. ****API1: BOLA (Broken Object Level Authorization):**** Objektų autorizacija kodo lygyje.
2. ****API2: Broken Authentication:**** Silpni slaptažodžiai, neapsaugoti tokenai.
3. ****API3: BOPLA (Object Property Level):**** Masinis priskyrimas (Mass Assignment).
4. ****API4: Unrestricted Resource Consumption:**** Trūksta Rate Limiting limitų.
5. ****API5: BFLA (Function Level Authorization):**** Prieiga prie administracinių funkcijų.
6. ****API6: Unrestricted Access to Sensitive Flows:**** Automatizuotų botų atakos.
7. ****API7: Server Side Request Forgery (SSRF):**** Manipuliacija vidinio tinklo užklausomis.
8. ****API8: Security Misconfiguration:**** Nutekinti stack traces, klaidingas CORS.
9. ****API9: Improper Inventory Management:**** Pamirštos senos API versijos.
10. ****API 10: Unsafe Consumption of APIs:**** Aklas pasitikėjimas trečiųjų šalių duomenimis.

```
## 2. Slaptų raktų apsauga prieš Git Commit `` ` bash #  
Patikrinti repozitoriją: gitleaks detect --source . -v # Pre-  
commit apsauga (.git/hooks/pre-commit): cat << 'EOF' >  
.git/hooks/pre-commit #!/bin/bash if git diff --cached |  
grep -E "(sk_live_|AlzaSy|AKIA[0-9A-Z]{16})"; then echo
```

```
"KLAIDA: Bandoma užcommitinti slapta API raktą!"    exit
1 fi EOF chmod +x .git/hooks/pre-commit `` `
```

OpenSSL ir SSL/TLS Sertifikatų Diagnostika per Terminalą

```
## 1. Nutolusio serverio sertifikato tikrinimas `` ` bash #
Pilnas testas: openssl s_client -connect
api.example.com:443 -servername api.example.com #
Sertifikato galiojimo data: echo | openssl s_client -
servername api.example.com -connect
api.example.com:443 2>/dev/null | openssl x509 -noout -
dates `` `
```

```
## 2. Sertifikato ir privataus rakto atitikimo (Modulus)
patikra `` ` bash # Jei MD5 maišos reikšmės sutampa –
raktas ir sertifikatas priklauso vienas kitam: openssl x509
-noout -modulus -in cert.pem | openssl md5 openssl rsa -
noout -modulus -in private.key | openssl md5 `` `
```

```
## 3. Šifrų ir TLS versijų palaikymo testavimas `` ` bash #
Patikrinti ar veikia TLS 1.3: openssl s_client -connect
api.example.com:443 -tls1_3 # Įsitikinti, kad pasenęs
protokolas yra blokuojamas: openssl s_client -connect
api.example.com:443 -tls1_1 `` `
```

Saugumo Audito ir CIS Kontrolinis Sąrašas

```
## 1. Vartotojų ir teisių auditas `` ` bash # Vartotojai be
slaptažodžio: awk -F: '($2 == "") {print "BE SLAPTAŽODŽIO:
" $1}' /etc/shadow # Neteisėti vartotojai su UID 0: awk -F:
'($3 == 0 && $1 != "root") {print "NETEISĖTAS ROOT: " $1}'
/etc/passwd # Sudoers teisės: grep -Po
'^sudo.+|^%sudo.+ ' /etc/sudoers `` `
```

```
## 2. Failų sistemas auditas `` ` bash # World-writable  
failai: find / -perm -o+w -type f 2>/dev/null | grep -v  
"/proc/" # SUID failai: find / -perm -4000 -type f  
2>/dev/null `` `
```

```
## 3. Automatinis auditas su Lynis `` ` bash sudo apt  
install lynis || brew install lynis sudo lynis audit system  
grep "Hardening index" /var/log/lynis.log grep "WARNING"  
/var/log/lynis.log `` `
```